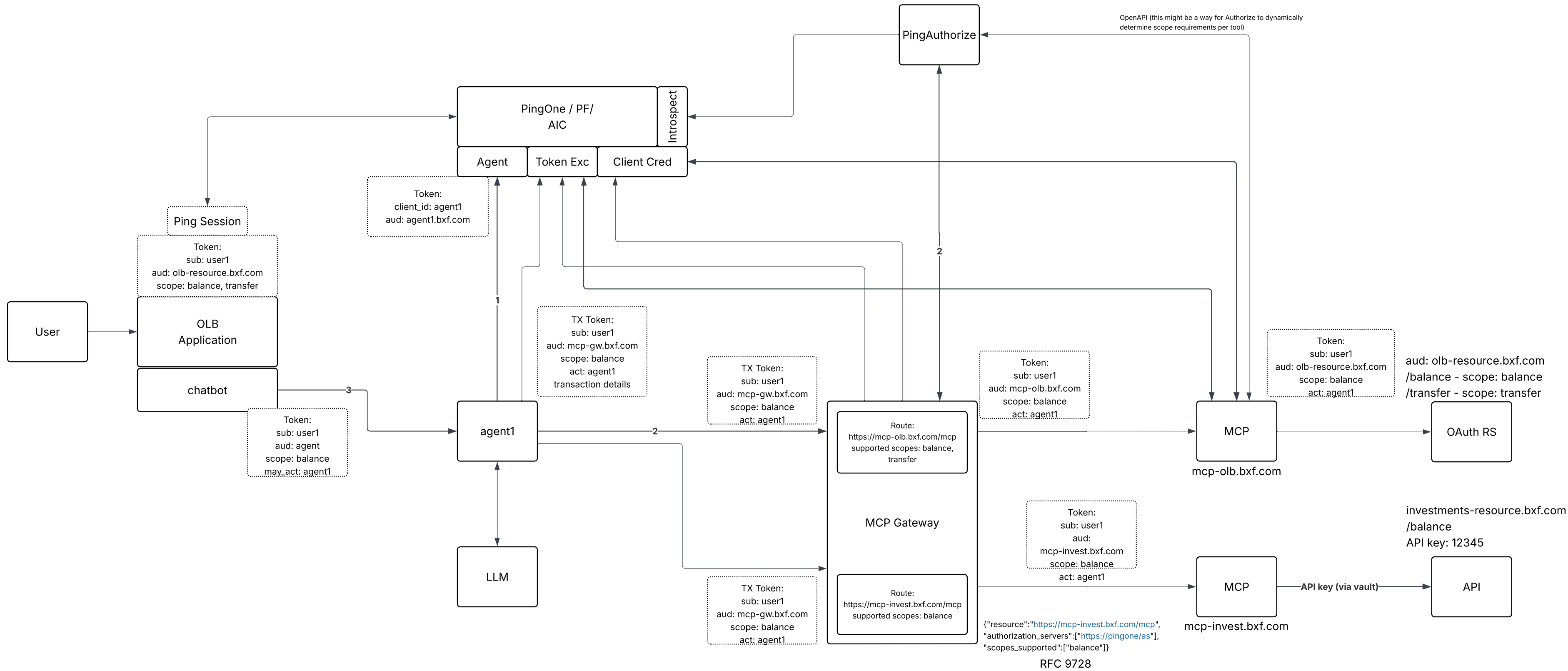




1. Agent starts, gets a token (client credentials, etc).
2. Agent gets tool list from the MCP gateway
 - 2a) Presents its own token, authorize returns permit/deny
3. User attempts to use chatbot to perform an action like check balance (check_balance mcp tool)
 - 3a) chatbot utilizes agent
 - 3b) agent uses LLM with MCP tool list and chatbot prompt to determine what tool to use
 - 3c) LLM informs agent it needs check_balance tool
4. Agent attempts to call the check_balance MCP tool
 - 4a) Gateway calls authorize
 - 4b) Authorize denies due to no subject (human) token
 - 4c) Authorize responds with required scope
 - 4d) Gateway returns JSON RPC unauthorized with required scope
5. Agent informs chatbot the user needs to login, and get a token with aud: agent1, scope: balance
 - 5a) Application logs user in, gets subject (human) token with may_act: agent1
6. Agent uses its own token (actor) + subject token to perform token exchange
 - 6a) TX token (aud: mcp-gw, scope: balance, TX details (id, prompt, etc)
 - Option: aud: mcp-olb (requires assurance that only path to MCP is via gateway)
7. MCP gateway calls authorize with TX token, and the tool call
- 7a) Authorize introspects, validates scopes, aud, tool call details vs. policy
- 7b) Authorize returns permit
8. Gateway performs token exchange for MCP
9. MCP performs token exchange for Resource
 - 9a) API use case: MCP users vault to get API key for Resource
10. Response
 - 10a) Resource response
 - 10b) MCP tool call response
 - 10c) agent response to chatbot
11. Human attempts transfer via chatbot
 - 11a) agent tries the action (transfer_money)
 - 11b) MCP gateway calls authorize
 - 11c) Authorize returns deny (required scope: transfer, HITL)
 - 11d) Gateway returns JSON RPC unauthorized with transfer scope and HITL requirement (i.e. step-up / consent) (**depends on agent capabilities**)
12. Agent invokes HITL (CIBA) and token exchange scope: balance transfer (retains original scope)
 - 12a) Repeat steps 6a - 10